Constituent Identity and Access Management Standard

From Minnesota IT Services, State of Minnesota

Version: 1.00
Issued Date: 8/1/2024
Effective Date: 9/1/2024
Approval: John Israel, State Chief Information Security Officer **Date:** 7/25/2024

Constituent Identity and Access Management (CIAM) is the practice of security that manages and controls access to digital services and resources for constituents of the State of Minnesota. This standard aims to provide guidelines for agencies to effectively implement the enterprise CIAM solution, ensuring security, privacy, and seamless single sign on user experience for Minnesota constituents. **All state digital services that require the public to share private data will move to the enterprise solution on login.mn.gov by July 1, 2027.**

Standard Statement

This standard applies to agencies that provide digital services and interacts with constituents or partners that support constituents consuming State services, including but not limited to interacting via a mobile application or traditional application.

This standard adheres to these principles when implementing the enterprise CIAM solution:

- **Privacy:** Agencies must prioritize constituent privacy by implementing measures to protect personal information, adhere to relevant data protection regulations and obtain explicit consent for data processing activities.
- **Security:** Robust security controls should be in place to safeguard constituent data against unauthorized access, breaches, and cyber threats. This includes encryption at rest and in transit, multi-factor authentication, identity proofing and regular security audits.
- **User Experience:** The enterprise CIAM solution provides a seamless and user-friendly experience. Providing the constituent with one State credential minimizes friction during authentication and authorization regardless of which State application the user is accessing.
- **Scalability**: The enterprise CIAM solution will be scalable to accommodate growing constituent bases and evolving business requirements without compromising performance or security.
- **Interoperability**: The enterprise CIAM solution will integrate seamlessly with existing system utilizing REST APIs and standard authentication and authorization methods of SAML and/or OIDC. If the application does not use these protocols, the enterprise solution can integrate using a proxy to covert older protocols to SAML or OIDC.

Table 1. Constituent Identity and Access Management Controls

Control Number	Control Name	Control Detail	Applicable Data Protection Categorization
1	Enterprise CIAM Solution	All agencies must integrate any constituent facing application with the enterprise CIAM solution to provide a single sign on experience for users.	Low Moderate High
2	Registration Process	There must be a streamlined registration process for constituents and partners, including options for self-service account creation.	Low Moderate High
3	Unique IDs	Every user must be assigned a unique ID, which is the user's email address, to access systems or data. Shared email addresses are prohibited.	Low Moderate High
4	Access Approval	Requests to grant or revoke access privileges for partners must be documented and approved by the application owner before access can be granted. Application owners must have access approval process. Each delegated administrator request for access must define access needs, including: • Systems and data that each user needs to access for their job function. • Level of privilege required (for example, user, administrator, etc.) for accessing resources. Requests for delegated administrator access must be approved by the application owner.	Moderate High
5	User Validation	A person must provide proof of their claimed identity when requesting access to an application based on data classification. The user's identity must be properly validated before any transaction that has information security implications, including modifying or communicating any authentication credential. For example, performing password or token resets, provisioning new tokens, or generating new keys.	Moderate High
6	Account Management	The addition, deletion, and modification of user IDs, credentials, and other identifier objects must be restricted to authorized delegated administrators. The Identity Management and Access Management (IAM) team, in conjunction with system/data	Low Moderate High

		owners will establish and maintain a list of roles and their associated rights.	
7	Profile Management	Constituents and partners must be able manage their profiles, including updating personal information, managing preferences, and configuring privacy settings.	Low Moderate High
8	Account Lockout	User accounts are locked out based on Azure smart lockout which takes into consideration the user's location and passwords entered. After three (3) unsuccessful password attempts, the account will be locked. The account must remain locked for at least one minute. After five (5) lockout periods, the time to retry increases in duration. Refer to Mitigate credential attacks - Azure AD B2C | Microsoft Learn for more details.	Low Moderate High
9	Fraud Detection	The Identity and Access Management solution must provide fraud detection to: Detect fraud patterns and identify returning devices based on device and location attributes. Reduce user latency by configuring specialized rules and policies. Protect against bot networks attempting to create synthetic accounts or gain access to accounts using stolen credentials.	
10	Authentication	Identity and Access Management solution must support various authentication methods such as passwords, biometrics, and multi-factor authentication (MFA) to verify constituent and partners identities securely. Multi-factor authentication (MFA) options must contain one of the following: • SMS • Voice • Authenticator applications • FIDO2 The solution must provide an option for the user to opt in for MFA.	Low Moderate High

		All authenticators must have sufficient strength for their intended use.	
11	Authorization	The solution must enforce access controls based on constituent attributes, roles, and permissions to ensure that constituents only have access to the resources and functionalities appropriate for their roles.	Low Moderate High
12	Single Sign On (SSO)	Constituents must enable access to multiple services and applications with a single credential, improving user experience and reducing authentication fatigue.	Low Moderate High
13	Password Encryption	All authentication credentials (such as passwords/phrases) must be cryptographically protected during transmission and storage.	Low Moderate High
14	Password Length	Passwords must be at least: • 8 characters long for constituents. • 12 characters long for partner accounts. • Feedback must be provided explaining password rejections.	Low Moderate High
15	Password Complexity	Passwords must contain at least: • 3 of the 4-character types below for user accounts and all mainframe accounts. Character Types: • Lower case letters • Upper case letters • Numbers • Special characters (optional) The use of dictionary names or single words must be prohibited. Passwords must be checked against a blacklist.	Low Moderate High
16	Maximum Password Age	Passwords/passphrases must be changed at least: • Every 30 days for partners. • Every 120 days for constituents.	Low Moderate High
17	Mask Password	By default, all passwords must be masked (i.e., made unreadable) when being entered to prevent unauthorized individuals from viewing the password.	Low Moderate High

18	Password History	New passwords/phrases must be different from at least the previous 6 passwords/phrases used by that account. Feedback must be provided explaining password rejections.	Low Moderate High
19	Entitlements	All access to systems or data, other than one time submission of data and read only access to data with a data protection categorization of Low, must be controlled using identification and authentication mechanisms. This access control must: • The Identity and Access Management (IAM) team, in collaboration with system/data owners will establish and maintain a list of roles and their associated rights/entitlements. • Assign privileges to individuals based on the individual's job classification and function. • Restrict privileges to the least needed for the individual or service to perform their role. • Deny all access that is not explicitly granted. • Remove all system access not explicitly required. • A justification must be provided when requesting a privileged role. • Data owner must review list of roles and entitlements every six (6) months and provide any changes to the Identity and Access Management team.	Low Moderate High
20	Revoke Entitlements	Partner and employee accounts and privileges that are no longer required must be removed or disabled within: • Eight (8) hours of notification or identification of voluntary changes in access needs. • One (1) hour of notification or identification for users that have been involuntarily terminated or for accounts with credentials that may have been lost or compromised.	Moderate High
21	Access Recertification	All partner and employee accounts must have an identified security liaison or supervisor. Users must comply with any required training for their role before the user can be recertified. All partner and employee accounts must be reviewed upon changes in user role and at least annually for user accounts. • The review must validate and recertify that all access privileges are still needed and authorized.	Moderate High

		• The results of the review must be documented, and unnecessary access privileges must be communicated to account administrators for removal. • Review documentation must be maintained by the account administrator for at least two (2) years and made available to the Enterprise Identity and Access Management team upon request. • Access will be revoked if supervisors or liaisons fail to certify access.	
22	Inactive Accounts	Inactive user accounts must be disabled after no more than 90 days of inactivity. Disabled user accounts must be deleted after 10 years. • Constituents • Partners • Employees • Contractors Inactive non-user accounts (including service, system, and device accounts) must be disabled after 180 days of inactivity. Disable all accounts that are only used annually when not in use.	Moderate High
23	Test Accounts	Accounts created for testing in a production environment must be disabled within 24 hours after testing has been completed.	Low Moderate High
24	Multiple Sessions	Systems must prevent multiple concurrent active sessions for individual user accounts. System and application accounts must be limited to the number of concurrent sessions needed for their purpose and as documented in the system security plan.	Low Moderate High
25	Session Termination	The information system must automatically terminate a user session as described below: • For Low systems, the session will terminate the user after 12 hours. • For Moderate systems, the session will terminate the user after four (4) hours. • For High systems, the session will terminate after 30 minutes.	Low Moderate High
26	Inactivity Timeout	The session must be automatically terminated after 15 minutes of application idle time. All information previously visible on the screen must be replaced with a publicly viewable image during the session lock. The user must be required to re-authenticate to reestablish the session.	Low Moderate High

27	System User Notification	For publicly accessible systems a warning banner must be displayed before allowing access. The warning banner must include: • The user is accessing a restricted government information system. • System usage may be monitored, recorded and subject to audit. • Unauthorized use of the system is prohibited and may be subject to criminal and/or civil penalties. • Use of the system indicates consent to monitoring and recording. For systems containing Federal Tax Information, the warning banner must reference the civil and criminal penalty sections of Title 26 Sections 7213, 7213A and 7431	Low Moderate High
28	Authorized Distribution	Users must ensure State data is only distributed to authorized personnel by: • Only allowing authorized personnel to view content on their screen. • Only including necessary and relevant information in system output such as reports and printouts. • Only distributing system output to individuals authorized to view all content.	Moderate High

Reason for the Standard

This standard is established to define requirements in meeting the State's obligation to ensure that users access to systems and services is based upon authorization and that unauthorized access is prevented. It is the responsibility of all systems owners to ensure appropriate controls, rules, access rights and restrictions are in place for their system and data.

Roles & Responsibilities

Employees and Contractors

- Be aware of and follow relevant information security policies, standards, and procedures.
- Ensure information security is incorporated into processes and procedures.
- Ensure contractors are following required information security controls.
- Contact information security staff or email iamsupport.mnit@state.mn.us with questions about the information security policies, standards, or procedures.

Partners With Delegated Administrator Access

- Be aware of and follow requirements in this document when managing constituent accounts.
- Report suspected account breaches to the appropriate State information security staff.

Supervisors and Managers

- Document roles, associated rights, business rules, and any access restrictions for their system and associated data.
- Ensure employees and contractors are proficient in the information security policies, standards and procedures that are relevant to their role.
- Hold employees accountable for following the information security policies, standards, and procedures.

Information Technology Personnel

- Apply appropriate controls to the design, operation and maintenance of systems, processes, and procedures in conformance with the information security policies, standards, and procedures.
- Do not use privileged accounts for non-administrator activities.

Information Security Personnel

- Develop and maintain access and entitlement review processes and procedures. Maintain this document.

Agency Data Practices Personnel

- Assist agencies and personnel with questions on proper data use, collection, storage, destruction, and disclosure.

Applicability

This standard applies to all information technology staff whose job duties include developing or implementing constituent and partner facing applications.

Related Information

Identity and Access Management Policy
Identity and Access Management Standard

History

Table 2. History

Version	Description	Date
Draft	Initial Draft	4/1/2024
1.0	Publish Date	8/1/2024

Contact

Questions regarding this standard can sent to data.security@state.mn.us.